PROJET TRACKIT

18 — Aspects juridiques et cadre légal

Obligations applicables à l'application web TrackIT en droit belge et européen : données personnelles, sécurité, cookies, droit d'auteur, information et responsabilité

Sommaire

1. Objet, périmètre et avertissement
2. Qualification juridique de TrackIT
3. Protection des données à caractère personnel
4. Sécurité des réseaux et des systèmes d'information (NIS2)
5. Cookies et stockage sur l'équipement terminal
6. Droit d'auteur et propriété intellectuelle
7. Obligations d'information et commerce électronique
8. Responsabilité
9. Synthèse et plan de mise en conformité
10. Conclusion

1. Objet, périmètre et avertissement

1.1 Objet

Ce document identifie les règles de droit applicables à TrackIT, application web de gestion des anomalies informatiques, et confronte chacune d'elles à l'état réel du projet. Il ne se limite pas à exposer le cadre légal : il indique, pour chaque obligation, si elle est satisfaite, partiellement satisfaite ou non satisfaite, et ce qu'il faudrait produire pour l'être.

1.2 Périmètre : droit belge et droit européen

L'analyse se place dans le cadre du droit belge et des règlements européens directement applicables. Les principaux textes mobilisés sont les suivants :

Domaine	Texte applicable	Autorité compétente
Données personnelles	Règlement (UE) 2016/679 (RGPD) ; loi du 30 juillet 2018 relative à la protection des personnes physiques à l'égard des traitements de données à caractère personnel	Autorité de protection des données (APD)
Données personnelles — Conseil de l'Europe	Convention 108 pour la protection des personnes à l'égard du traitement automatisé des données, modernisée par le Protocole 108+	—
Sécurité des systèmes	Directive (UE) 2022/2555 (NIS2) ; loi du 26 avril 2024 établissant un cadre pour la cybersécurité ; arrêté royal du 9 juin 2024	Centre pour la Cybersécurité Belgique (CCB)
Cookies et équipement terminal	Article 129 de la loi du 13 juin 2005 relative aux communications électroniques, combiné au RGPD pour la définition du consentement	Autorité de protection des données (APD)
Droit d'auteur et logiciels	Livre XI du Code de droit économique (CDE), titres 5 et 6	Office de la Propriété intellectuelle ; tribunaux
Commerce électronique	Livre XII du Code de droit économique (services de la société de l'information)	SPF Économie ; Inspection économique
Responsabilité des intermédiaires	Articles XII.17 à XII.20 du CDE ; Règlement (UE) 2022/2065 (DSA), applicable depuis le 17 février 2024	Coordinateur pour les services numériques
Relations entre entreprises	Livre VI du CDE, clauses abusives entre entreprises (loi du 4 avril 2019)	SPF Économie

1.3 Avertissement

Portée de ce document

Cette analyse est un travail académique réalisé dans le cadre d'un projet de fin d'études. Elle ne constitue **pas un avis juridique** et n'engage pas la responsabilité de son auteur. Une mise en service réelle de TrackIT, et plus encore une commercialisation, devraient être précédées de la validation des documents contractuels par un conseil juridique. Les textes cités sont ceux en vigueur à la date de rédaction ; leur évolution devra être suivie.

2. Qualification juridique de TrackIT

2.1 Nature du service

TrackIT est un **service de la société de l'information** au sens du Livre XII du Code de droit économique : un service presté à distance, par voie électronique, à la demande individuelle d'un

destinataire, et — dès lors qu'une offre payante existe — contre rémunération. Cette qualification emporte des obligations d'information précises, examinées au chapitre 7.

Le service est destiné à des **organisations**, non à des consommateurs. La relation est donc de nature professionnelle, ce qui écarte l'essentiel du droit de la consommation mais n'écarte pas le régime des clauses abusives entre entreprises, introduit par la loi du 4 avril 2019.

2.2 Une double qualification au sens du RGPD

C'est le point de qualification le plus important, et celui qui est le plus souvent manqué dans les projets de ce type. TrackIT n'a pas un rôle unique au regard du RGPD : il en a **deux**, selon les données considérées.

Données concernées	Qui décide des finalités	Rôle de TrackIT	Conséquence principale
Comptes des utilisateurs des organisations clientes, anomalies déclarées, commentaires, pièces jointes, historique	L'organisation cliente, qui choisit d'outiller son suivi d'incidents	**Sous-traitant** (art. 4.8 RGPD)	Un contrat de sous-traitance conforme à l'article 28 est **obligatoire** avec chaque organisation cliente
Compte de l'organisation elle-même, données d'abonnement et de facturation, journaux techniques	TrackIT, pour gérer sa relation commerciale et son service	**Responsable du traitement** (art. 4.7 RGPD)	TrackIT doit informer directement les personnes et répondre lui-même de leurs droits

La distinction n'est pas théorique. Elle détermine qui informe les personnes concernées, qui répond à une demande d'accès ou d'effacement, qui notifie une violation de données et à qui. En tant que sous-traitant, TrackIT ne répond pas directement aux salariés de ses clients : il **assiste** son client, qui reste l'interlocuteur des personnes. En tant que responsable, il répond directement.

Écart constaté

Aucun document ne formalise aujourd'hui cette répartition. Il n'existe ni contrat de sous-traitance, ni politique de confidentialité, ni mention indiquant aux utilisateurs qui est responsable de quoi. C'est le premier manquement à corriger, car tous les autres documents en découlent.

2.3 Acteurs et flux de données

Acteur	Rôle	Données auxquelles il accède
Organisation cliente	Responsable du traitement	Toutes les données de son organisation
TrackIT (éditeur)	Sous-traitant, et responsable pour ses propres traitements	Techniquement l'ensemble des données hébergées
Hébergeur	Sous-traitant ultérieur de TrackIT	Données hébergées, sans accès fonctionnel
Stripe	Responsable du traitement pour les données de paiement	Données de paiement ; TrackIT n'en conserve aucune
Utilisateur final	Personne concernée	Les données que ses droits lui permettent de consulter

Le recours à un hébergeur et à Stripe constitue une **sous-traitance ultérieure** au sens de l'article 28.2 du RGPD : elle suppose l'autorisation de l'organisation cliente, généralement donnée de façon générale dans le contrat, assortie d'une information préalable en cas de changement de prestataire.

3. Protection des données à caractère personnel

3.1 Données traitées et base de licéité

Tout traitement doit reposer sur l'une des bases de l'article 6 du RGPD. Le tableau ci-dessous recense les données effectivement présentes dans la base de TrackIT et la base qui les justifie.

Donnée	Finalité	Base de licéité	Rôle de TrackIT
Nom, prénom	Identifier l'auteur d'une déclaration ou d'une action	Exécution du contrat (art. 6.1.b) entre le client et son salarié, ou intérêt légitime (art. 6.1.f)	Sous-traitant
Adresse e-mail professionnelle	Authentifier, notifier	Exécution du contrat (art. 6.1.b)	Sous-traitant
Empreinte du mot de passe	Authentifier	Exécution du contrat (art. 6.1.b)	Sous-traitant
Rôle et organisation	Déterminer les droits d'accès	Intérêt légitime (art. 6.1.f)	Sous-traitant
Contenu des anomalies et commentaires	Traiter l'incident	Intérêt légitime de l'organisation (art. 6.1.f)	Sous-traitant
Historique horodaté des actions	Tracer, prouver, sécuriser	Intérêt légitime (art. 6.1.f) ; obligation de sécurité (art. 32)	Sous-traitant
Données d'abonnement et de facturation	Gérer la relation commerciale	Exécution du contrat (art. 6.1.b) ; obligation légale comptable (art. 6.1.c)	Responsable

Aucune **catégorie particulière** de données au sens de l'article 9 — santé, opinions, données biométriques — n'est traitée. C'est un point favorable : il écarte le régime renforcé de l'article 9 et allège l'appréciation du risque. Une vigilance subsiste toutefois sur les **pièces jointes** : rien n'empêche techniquement un utilisateur d'y déposer une capture d'écran contenant des données sensibles. Les conditions générales devront l'interdire expressément.

3.2 Principes de l'article 5 confrontés à l'application

Principe	État dans TrackIT	Appréciation
Licéité, loyauté, transparence	Les traitements reposent sur des bases identifiables, mais aucune information n'est délivrée aux personnes	**Non satisfait**
Limitation des finalités	Les données ne servent qu'au suivi des anomalies et à la gestion des comptes	Satisfait
Minimisation	Seuls nom, prénom, e-mail, rôle et organisation sont collectés ; ni téléphone, ni adresse, ni date de naissance	Satisfait
Exactitude	Chaque utilisateur peut corriger ses informations depuis son profil	Satisfait
Limitation de la conservation	Aucune durée n'est définie ni appliquée ; les données sont conservées sans limite	**Non satisfait**
Intégrité et confidentialité	Cloisonnement par organisation, contrôle d'accès par rôle, mots de passe chiffrés (voir livrable 16)	Largement satisfait
Responsabilité (accountability)	Aucun registre des traitements, aucune documentation des mesures	**Non satisfait**

3.3 Droits des personnes concernées

Les articles 12 à 22 du RGPD ouvrent aux personnes une série de droits. Le tableau indique, pour chacun, ce que TrackIT permet aujourd'hui.

Droit	Article	État dans l'application
Information	12 à 14	Aucune politique de confidentialité ni mention à la création de compte
Accès	15	Partiellement : l'utilisateur voit son profil, mais aucun export global
Rectification	16	Satisfait : modification du profil en autonomie
Effacement (« droit à l'oubli »)	17	Aucune fonction ; la suppression d'un compte par l'administrateur n'est pas documentée quant à ses effets
Limitation du traitement	18	Aucune fonction ; la désactivation du compte s'en approche sans la réaliser
Portabilité	20	Aucune fonction d'export des données au format réutilisable
Opposition	21	Sans objet pour l'essentiel : les traitements reposent sur le contrat, non sur l'intérêt légitime seul

Une précision de méthode s'impose sur le droit à l'effacement. Supprimer purement et simplement un utilisateur viderait l'historique de son auteur et ferait perdre à l'organisation la traçabilité exigée par ailleurs. La solution conforme est l'**anonymisation** : remplacer nom et adresse par une mention neutre tout en conservant l'enregistrement. Une donnée anonymisée n'étant plus une donnée personnelle, elle sort du champ du RGPD et peut être conservée.

3.4 Obligations documentaires

Obligation	Article	Applicable à TrackIT ?	État
Registre des activités de traitement	30	Oui, pour les deux rôles. L'exemption des moins de 250 salariés ne joue pas : le traitement n'est pas occasionnel	**Absent**
Contrat de sous-traitance	28	Oui, avec chaque organisation cliente et avec l'hébergeur	**Absent**
Analyse d'impact (AIPD)	35	A priori non : pas de données sensibles, pas de profilage, pas de surveillance systématique. À réévaluer en cas d'évolution	**Non requise**
Délégué à la protection des données	37	Non : ni autorité publique, ni suivi à grande échelle, ni données de l'article 9	**Non requis**
Information des personnes	13 et 14	Oui, pour les traitements dont TrackIT est responsable	**Absent**
Notification des violations à l'APD	33	Oui, dans les 72 heures ; en tant que sous-traitant, TrackIT doit alerter son client « dans les meilleurs délais »	Procédure absente
Communication aux personnes	34	Oui, si le risque est élevé pour les droits et libertés	Procédure absente

3.5 Transferts hors Union européenne

L'application fait appel à Stripe pour l'encaissement des abonnements. Ce point mérite un examen, car le chapitre V du RGPD encadre strictement les transferts hors de l'Union.

Deux éléments jouent en faveur de TrackIT. D'une part, **aucune donnée bancaire n'est stockée** par l'application : le paiement est entièrement délégué, ce qui réduit du même coup le périmètre des exigences du standard PCI-DSS. D'autre part, Stripe opère ses services européens depuis une entité établie en Irlande. Il n'en demeure pas moins qu'un transfert vers les États-Unis peut intervenir au sein du groupe : il doit alors reposer sur un fondement du chapitre V — décision d'adéquation ou clauses contractuelles types.

À documenter

La localisation de l'hébergement n'est pas davantage déterminée dans le projet. Un hébergement dans l'Union évite toute question de transfert et constitue, pour une clientèle professionnelle européenne, un argument commercial. Ce choix doit être arrêté puis mentionné dans le contrat de sous-traitance et dans la politique de confidentialité.

4. Sécurité des réseaux et des systèmes d'information (NIS2)

4.1 Cadre applicable

La directive (UE) 2022/2555, dite **NIS2**, a été transposée en droit belge par la **loi du 26 avril 2024** établissant un cadre pour la cybersécurité des réseaux et des systèmes d'information d'intérêt général pour la sécurité publique, entrée en vigueur le **18 octobre 2024** et complétée par l'arrêté royal du 9 juin 2024. Le **Centre pour la Cybersécurité Belgique (CCB)** en est l'autorité nationale ; c'est à lui que les incidents significatifs doivent être notifiés.

4.2 TrackIT entre-t-il dans le champ d'application ?

La réponse est **non en l'état**, et il importe d'expliquer pourquoi plutôt que de l'affirmer. NIS2 s'applique aux entités essentielles et importantes des secteurs qu'elle énumère, sous réserve d'un critère de taille : à partir de cinquante salariés ou de dix millions d'euros de chiffre d'affaires annuel. Un éditeur de logiciel en mode service peut relever de la catégorie des fournisseurs de services numériques ou de services gérés, mais un projet de fin d'études n'atteint évidemment aucun de ces seuils.

Deux raisons justifient néanmoins de traiter le sujet. D'abord parce que les **organisations clientes**, elles, peuvent être soumises à NIS2 : elles exigeront alors de leurs fournisseurs des garanties de sécurité, la directive imposant expressément la maîtrise des risques liés à la chaîne d'approvisionnement. Ensuite parce que le franchissement des seuils, en cas de croissance, rendrait la conformité exigible sans délai : il est moins coûteux de concevoir en conséquence que de se mettre en conformité après coup.

4.3 Articulation entre le RGPD et NIS2

Les deux textes imposent des mesures de sécurité, mais ils ne poursuivent pas le même but, et les confondre conduit à des contresens.

	RGPD	NIS2
Ce qui est protégé	Les droits et libertés des personnes	La continuité des services et la résilience des systèmes
Déclencheur de notification	Violation de données personnelles (confidentialité, intégrité, disponibilité)	Incident ayant un impact significatif sur la fourniture du service
Destinataire	Autorité de protection des données, et les personnes si risque élevé	Centre pour la Cybersécurité Belgique
Délai	72 heures	Alerte précoce sous 24 heures, puis notification sous 72 heures
Qui est concerné	Tout responsable ou sous-traitant	Les entités des secteurs visés dépassant les seuils

Un même incident — une intrusion conduisant au vol de la base — peut relever des deux régimes et appeler **deux notifications distinctes**, à deux autorités différentes et selon deux calendriers. La procédure de gestion des violations proposée au livrable 16 devra donc prévoir les deux branches.

5. Cookies et stockage sur l'équipement terminal

5.1 Cadre applicable

La matière est régie par l'**article 129 de la loi du 13 juin 2005** relative aux communications électroniques, qui transpose la directive « vie privée et communications électroniques ». La règle est plus large que ce que le terme « cookies » laisse entendre : elle vise **tout stockage d'informations,**

ou tout accès à des informations déjà stockées, dans l'équipement terminal de l'utilisateur. Le stockage local d'un navigateur y est donc soumis au même titre qu'un cookie.

Le principe est le consentement préalable, assorti d'une exception : les dispositifs **strictement nécessaires** à la fourniture d'un service expressément demandé par l'utilisateur en sont dispensés. Depuis le RGPD, le consentement requis doit être libre, spécifique, éclairé et univoque — ce qui exclut les cases pré-cochées et la poursuite de la navigation comme forme d'acceptation.

5.2 Analyse de TrackIT

Situation favorable

L'examen du code établit que l'application **ne dépose aucun cookie** et n'intègre **aucun traceur publicitaire ni outil de mesure d'audience**. Le seul stockage sur le poste de l'utilisateur est le jeton de session, placé dans le stockage local ou de session du navigateur selon que l'option « Se souvenir de moi » est cochée, ainsi que quelques préférences d'affichage.

Ce stockage relève de l'exception : il est strictement nécessaire au maintien de la session d'un service que l'utilisateur a expressément demandé en se connectant. **Aucun bandeau de consentement n'est donc requis en l'état.** Une information demeure néanmoins due au titre de la transparence : la politique de confidentialité devra décrire ce stockage, sa finalité et sa durée.

5.3 Conséquence directe du livrable 17

Ce constat favorable est fragile, et il faut le signaler explicitement car les deux livrables se contrediraient sans cette précision. La stratégie de référencement propose d'installer un **outil d'analyse d'audience** pour mesurer le taux de conversion. Un tel outil dépose des identifiants qui ne sont pas strictement nécessaires au service demandé.

Le jour où cette mesure sera mise en œuvre, l'exception cessera de s'appliquer et l'application devra se doter d'un **bandeau de consentement conforme** : refus aussi simple que l'acceptation, aucun dépôt avant le choix, conservation de la preuve du consentement et possibilité de le retirer. Deux voies permettent de l'éviter : retenir une solution de mesure d'audience exemptée de consentement, configurée sans suivi individuel, ou se limiter à l'analyse des journaux du serveur.

6. Droit d'auteur et propriété intellectuelle

6.1 Protection du logiciel

En droit belge, les programmes d'ordinateur sont protégés par le droit d'auteur, au titre du **Livre XI du Code de droit économique**. La protection naît du seul fait de la création, sans dépôt ni formalité, dès lors que l'œuvre est **originale** — c'est-à-dire qu'elle porte l'empreinte de la personnalité de son auteur. Elle couvre le code source et le code objet, ainsi que le matériel de conception préparatoire, mais **non les idées ni les principes** qui sont à la base du logiciel : un concurrent reste libre de développer un outil de gestion d'anomalies, pourvu qu'il n'en reprenne pas le code.

Les droits patrimoniaux durent soixante-dix ans après la mort de l'auteur. S'y ajoutent des droits moraux, dont le droit à la paternité, qui ne se cèdent pas.

6.2 Titularité des droits sur TrackIT

Le principe est que l'auteur est la **personne physique** qui a créé l'œuvre. Le Code prévoit une exception pour les logiciels créés par un salarié dans l'exercice de ses fonctions : les droits patrimoniaux sont alors présumés cédés à l'employeur, sauf convention contraire. Cette exception ne s'applique pas de plein droit à un travail d'étudiant, qui n'est pas lié par un contrat de travail.

En conséquence, **l'étudiant demeure en principe titulaire des droits sur TrackIT**, sous réserve du règlement des études de l'établissement, que certaines institutions assortissent de clauses de cession ou de licence. Il convient de vérifier ce règlement avant toute publication ou exploitation, et de clarifier

la situation si plusieurs personnes ont contribué au code — la **cotitularité** née d'une création conjointe impose l'accord de tous pour l'exploitation.

6.3 Licences des composants tiers

TrackIT n'est pas écrit à partir de rien : il intègre une dizaine de bibliothèques tierces, chacune soumise à sa propre licence. Le respect de ces licences est une obligation juridique, pas une convenance. Les licences ci-dessous ont été relevées dans les fichiers de description des bibliothèques effectivement utilisées.

Composant	Licence	Nature	Contrainte principale
Spring Boot (web, data, security, validation)	Apache 2.0	Permissive	Conserver les mentions de copyright et le texte de licence
Flyway	Apache 2.0	Permissive	Idem
springdoc-openapi	Apache 2.0	Permissive	Idem
jjwt (JSON Web Token)	Apache 2.0	Permissive	Idem
Apache POI	Apache 2.0	Permissive	Idem
stripe-java	MIT	Permissive	Conserver la mention de copyright
Lombok	MIT	Permissive	Idem
OpenPDF	LGPL 2.1 et MPL (double licence)	Faiblement copyleft	Utilisation par simple liaison admise ; modifications de la bibliothèque à republier
H2 (tests uniquement)	MPL 2.0 et EPL 1.0	Faiblement copyleft	Portée limitée : dépendance de test, non distribuée
mysql-connector-j	**GPL v2 avec Universal FOSS Exception v1.0**	Fortement copyleft	**Voir le point 6.4**

6.4 Point d'attention : le connecteur MySQL

Incompatibilité potentielle avec une diffusion propriétaire

Le pilote `mysql-connector-j`, qui assure la connexion à la base de données, est distribué sous **licence GPL version 2**, assortie d'une exception dite « Universal FOSS Exception ». Cette exception autorise la liaison depuis une application distribuée sous une licence libre figurant sur la liste approuvée. En revanche, une distribution de TrackIT sous licence **propriétaire** ne bénéficierait pas de l'exception : il faudrait alors soit acquérir une licence commerciale auprès d'Oracle, soit publier TrackIT sous une licence libre compatible, soit remplacer le pilote par une alternative permissive — MariaDB Connector/J, sous LGPL, est la voie la plus simple.

La question ne se pose pas dans le cadre académique actuel, puisqu'il n'y a pas de distribution au sens de la GPL. Elle se poserait dès la première livraison du logiciel à un tiers, et c'est le genre de point qu'il est beaucoup moins coûteux d'arbitrer avant qu'après.

6.5 Licence du projet lui-même

Écart — aucune licence déclarée

Le projet ne comporte aucun fichier de licence. En l'absence de mention, le droit d'auteur s'applique par défaut dans toute sa rigueur : **tous droits réservés**. Personne n'est autorisé à copier, modifier ou réutiliser le code, même publié sur un dépôt accessible. Publier le code sans licence crée donc une situation ambiguë : le code est visible mais juridiquement inutilisable. **Mesure proposée :** ajouter un fichier `LICENSE` exprimant l'intention — une licence permissive de type MIT pour autoriser la réutilisation, ou une mention explicite de tous droits réservés pour une simple consultation.

Un second fichier mérite d'accompagner le premier : un relevé des composants tiers et de leurs licences, qui satisfait l'obligation de conserver les mentions de copyright imposée par les licences Apache et MIT.

7. Obligations d'information et commerce électronique

7.1 Mentions légales obligatoires

Le Livre XII du Code de droit économique impose à tout prestataire de services de la société de l'information de rendre accessibles, de manière facile, directe et permanente, un ensemble d'informations d'identification.

Information exigée	Présente sur le site ?
Dénomination ou nom du prestataire	**Non**
Adresse géographique d'établissement	**Non**
Adresse électronique de contact	**Oui : une adresse figure en bas de la page d'accueil**
Numéro d'entreprise (BCE) et numéro de TVA, le cas échéant	**Non**
Coordonnées de l'autorité de surveillance, si activité réglementée	Sans objet
Prix indiqués de manière claire, mention des taxes et frais	**Partiellement : une grille tarifaire existe, sans précision sur la TVA**
Conditions générales accessibles et conservables	**Non**

Sur sept informations attendues, une seule est présente. C'est, avec l'absence de politique de confidentialité, le manquement le plus immédiatement visible : il ne suppose aucun développement, seulement la rédaction d'une page et un lien dans le pied de page du site.

7.2 Conditions générales d'utilisation

Aucune condition générale n'existe. Elles constituent pourtant le socle contractuel de la relation avec les organisations clientes et devront traiter au minimum : l'objet du service et son périmètre ; les obligations de l'utilisateur, dont l'interdiction de déposer des données sensibles en pièce jointe ; la disponibilité du service et les éventuels engagements de niveau ; la propriété intellectuelle sur la plateforme et sur les contenus déposés ; la durée, la résiliation et le **sort des données en fin de contrat** ; la limitation de responsabilité ; le droit applicable et le tribunal compétent.

Deux points méritent une attention particulière. La **restitution des données** à la fin du contrat est une attente forte des clients professionnels et découle de la qualification de sous-traitant : l'article 28 impose de restituer ou de supprimer les données au terme de la prestation, au choix du responsable. Et les clauses limitatives de responsabilité doivent rester mesurées : la loi du 4 avril 2019 sanctionne les clauses manifestement déséquilibrées **même entre entreprises**, et une clause excluant toute responsabilité serait réputée non écrite.

7.3 Souscription de l'abonnement en ligne

L'offre Premium est souscrite en ligne par voie électronique. Le Livre XII impose alors un parcours de commande explicite : description claire du service et du prix, récapitulatif avant validation, possibilité de corriger les erreurs de saisie, et **accusé de réception** de la commande sans délai injustifié. Le client étant une entreprise et non un consommateur, le droit de rétractation de quatorze jours ne s'applique pas — ce qui mérite d'être écrit dans les conditions générales pour éviter toute ambiguïté.

8. Responsabilité

8.1 Responsabilité quant aux contenus

TrackIT héberge des contenus produits par ses utilisateurs : descriptions d'anomalies, commentaires, pièces jointes. La question de la responsabilité de l'éditeur à leur égard relève du régime des **prestataires intermédiaires**, prévu aux articles XII.17 à XII.20 du Code de droit économique et désormais complété par le règlement européen sur les services numériques, applicable depuis le 17 février 2024.

Le principe est celui d'une responsabilité **atténuée** : l'hébergeur n'est pas responsable des contenus stockés à condition qu'il n'ait pas connaissance de leur caractère illicite et qu'il agisse promptement pour les retirer dès qu'il en a connaissance. Aucune obligation générale de surveillance ne pèse sur lui. Ce régime s'applique naturellement à TrackIT, qui ne sélectionne ni ne modifie les contenus déposés par les utilisateurs.

La conséquence pratique est l'existence d'une **procédure de signalement** : un moyen pour un tiers de porter un contenu illicite à la connaissance de l'éditeur, et une capacité de retrait rapide. Dans le contexte de TrackIT, où les contenus sont internes à chaque organisation et invisibles de l'extérieur, le risque est faible, mais la procédure doit exister.

8.2 Responsabilité contractuelle et obligation de sécurité

Au-delà des contenus, l'éditeur répond de la bonne exécution du service. Deux sources d'obligation se cumulent. Sur le plan contractuel, les engagements pris dans les conditions générales — disponibilité, assistance — engagent leur auteur ; mieux vaut donc une **obligation de moyens** clairement formulée qu'un engagement de résultat implicite. Sur le plan réglementaire, l'article 32 du RGPD impose des mesures techniques et organisationnelles appropriées : un manquement de sécurité ayant conduit à une violation de données expose à une sanction administrative, indépendamment de tout préjudice contractuel.

C'est le lien direct avec le livrable 16 : les écarts de sécurité qui y sont identifiés — absence de chiffrement du transport, absence de limitation des tentatives de connexion, absence de journal de sécurité — ne sont pas seulement des faiblesses techniques. Ils constituent, en cas d'incident, autant d'éléments susceptibles de caractériser un manquement à l'article 32.

9. Synthèse et plan de mise en conformité

9.1 Ce qui est déjà conforme

L'analyse ne relève pas que des manques. Plusieurs choix de conception vont dans le sens de la conformité, souvent sans qu'ils aient été faits pour cette raison :

- **minimisation des données** : seules cinq informations personnelles sont collectées, toutes nécessaires au service ;
- **aucune donnée sensible** au sens de l'article 9, ce qui écarte le régime renforcé ;
- **aucune donnée bancaire conservée** : le paiement est délégué, ce qui réduit aussi le périmètre PCI-DSS ;
- **aucun cookie ni traceur** : pas de bandeau de consentement requis en l'état ;
- **cloisonnement et contrôle d'accès** effectifs, qui servent directement l'article 32 ;
- **droit de rectification** satisfait par la page de profil ;
- **licences tierces** majoritairement permissives, sans contrainte de réciprocité.

9.2 Documents à produire

La mise en conformité passe davantage par la rédaction de documents que par du développement. Six documents couvrent l'essentiel des obligations :

Document	Fondement	Destinataire	Priorité
Mentions légales	Livre XII du CDE	Tout visiteur du site	1
Politique de confidentialité	Articles 13 et 14 du RGPD	Utilisateurs et visiteurs	1
Conditions générales d'utilisation	Droit commun des contrats ; Livre XII du CDE	Organisations clientes	1
Contrat de sous-traitance	Article 28 du RGPD	Chaque organisation cliente	2
Registre des activités de traitement	Article 30 du RGPD	Interne ; produit à l'APD sur demande	2
Procédure de gestion des violations	Articles 33 et 34 du RGPD ; NIS2 le cas échéant	Interne	3

9.3 Plan d'action

Les actions sont classées par priorité juridique, en distinguant la rédaction du développement.

Priorité	Action	Nature	Chap.	Effort
J1	Publier les mentions légales et un lien permanent en pied de page	Rédaction	7.1	0,5 j
J2	Rédiger et publier la politique de confidentialité	Rédaction	3	1 j
J3	Rédiger les conditions générales d'utilisation	Rédaction	7.2	2 j
J4	Ajouter un fichier de licence et le relevé des composants tiers	Rédaction	6.5	0,5 j
J5	Établir le contrat de sous-traitance type (article 28)	Rédaction	3.4	2 j
J6	Constituer le registre des activités de traitement	Rédaction	3.4	1 j
J7	Définir et appliquer les durées de conservation	Développement	3.2	2 j
J8	Développer l'export des données et l'anonymisation des comptes	Développement	3.3	3 j
J9	Formaliser la procédure de notification des violations	Rédaction	3.4	1 j
J10	Arbitrer la licence du connecteur de base de données	Décision	6.4	0,5 j
J11	Documenter l'hébergement et les transferts hors Union	Décision	3.5	0,5 j
J12	Prévoir le bandeau de consentement si une mesure d'audience est ajoutée	Conditionnel	5.3	1 j

Les six premières actions ne demandent aucune ligne de code et couvrent les manquements les plus visibles de l'extérieur, pour environ sept jours de rédaction.

10. Conclusion

L'examen juridique de TrackIT fait apparaître un déséquilibre instructif. Les obligations qui touchent à la **conception technique** sont largement satisfaites : données collectées minimales, aucune catégorie sensible, aucune donnée bancaire conservée, aucun traceur, cloisonnement effectif, licences tierces presque toutes permissives. Ces résultats découlent de choix d'ingénierie conformes par construction.

Les obligations qui touchent à la **formalisation** ne le sont pas. Il n'existe ni mentions légales, ni politique de confidentialité, ni conditions générales, ni contrat de sous-traitance, ni registre des traitements, ni licence déclarée sur le code. Or ce sont précisément les éléments qu'un tiers — une organisation cliente, un auditeur, une autorité de contrôle — examine en premier, parce qu'ils sont visibles sans accès au code.

Un point de qualification conditionne l'ensemble : TrackIT occupe **deux positions distinctes** au regard du RGPD, sous-traitant pour les données de ses clients et responsable pour les siennes. Cette dualité détermine qui informe, qui répond aux demandes des personnes et qui notifie une violation. Tant qu'elle n'est pas écrite dans un contrat, la répartition des responsabilités reste indéterminée — ce qui expose l'éditeur autant que ses clients.

Enfin, cette analyse ne se lit pas isolément. L'absence de chiffrement du transport relevée au livrable 16 n'est pas seulement une faiblesse technique : c'est un élément susceptible de caractériser un manquement à l'obligation de sécurité de l'article 32. Et la mesure d'audience proposée au livrable 17 ferait basculer l'application dans le régime du consentement préalable. La conformité juridique n'est pas un chapitre séparé du projet : elle est la conséquence des choix techniques et commerciaux qui y sont faits.